

On Security Vulnerabilities in Transportation IoT Devices

Jason Yih
University of Maryland
College Park, MD
jyih@umd.edu

Katerina Goseva-Popstojanova
West Virginia University
Morgantown, WV
Katerina.Goseva@mail.wvu.edu

Michel Cukier
University of Maryland
College Park, MD
mcukier@umd.edu

Abstract—This paper extends our previous empirical study of security vulnerabilities in Electric Vehicle (EV) Chargers, EVs, Non-EVs, and Other Traffic Devices [1]. Using data extracted from the National Vulnerability Database (NVD), we collected and analyzed a list of 1580 Common Vulnerabilities and Exposures (CVEs) (compared to 159 in [1]). The investigation explores the Common Weakness Enumeration (CWE) and Common Vulnerability Scoring System (CVSS) information for each vulnerability. Our results indicate an uneven distribution of the security vulnerabilities, as the six most dominant classes represent between 65% and 86% of all vulnerabilities in each category (compared to 74% to 89% in [1]). EV Chargers and Other Traffic Devices had equal median CVSS scores, statistically significantly higher than both EVs and Non-EVs. In addition, EV Chargers had the highest proportion of vulnerabilities that can be exploited through the network, as well as vulnerabilities that affect components outside of the original scope. The paper outlines the practical implications and key lessons learned from this empirical study.

Abstract—This paper presents an empirical investigation of security vulnerabilities in four categories of transportation IoT devices: Electric Vehicle (EV) Chargers, EVs, non-EVs, and Other Traffic Devices. The results are based on data extracted from the Common Vulnerabilities and Exposures (CVEs) reported in the National Vulnerability Database (NVD). We analyzed 159 CVEs and explored the CWE (Common Weakness Enumeration) and CVSS (Common Vulnerability Scoring System) information associated with them. Our results showed that the security vulnerabilities were distributed unevenly across the 23 vulnerability classes, with the top six most common classes accounting for 74% to 89% of all vulnerabilities in each category of IoT devices. EV Chargers had the highest mean and median CVSS severity score, followed by Other Traffic Devices and EVs. Non-EVs had the lowest CVSS, which were statistically significantly different than the other categories of transportation IoT devices. The paper also presents the lessons learned and the practical implications of our empirical findings.

Index Terms—Security vulnerabilities, severity, transportation IoT devices, empirical study.

I. INTRODUCTION

The landscape of transportation systems is undergoing rapid changes, driven by increasing connectivity and integration of vehicles, traffic control, and infrastructure into the Internet of Things (IoT). This connectivity is essential for modern functionality and convenience, but it increases cybersecurity risks. As components of the critical infrastructure, these connected transportation devices are becoming more frequent and important targets for malicious actors. For example, the

transportation industry was identified as the fifth most common target of cyberattacks in 2024, accounting for 7% of the total reported attacks [2]. This is an increase from 2023, where the industry was the eighth most common target. The increasing adoption of these technologies introduces a corresponding increase in vulnerabilities, directly translating into higher risks and requiring safety precautions.

To better understand the risks introduced with transportation IoT devices, this paper presents an empirical study on security vulnerabilities in these devices. This paper is an extension of our previous paper, [1], focusing on vulnerabilities in four categories: Electric Vehicles (EVs), Non-EVs, EV Chargers, and Other Traffic Devices that are connected to the Internet. We collect Common Vulnerabilities and Exposures (CVEs) related to these devices through NIST's National Vulnerability Database (NVD) [3], along with the underlying weaknesses causing them (i.e., Common Weakness Enumeration (CWEs)), severity (i.e., Common Vulnerability Scoring System (CVSS) scores and severities), and additional details about the vulnerability (i.e., CVSS Vector). Then, following the approach introduced in [4] and used in our previous paper, we group the individual CWE information into the 23 primary vulnerability classes of the CWE-888 Software Fault Patterns view [5]. In addition, we analyze the CVSS scores associated with the vulnerabilities, along with the metrics used to calculate them.

In this paper, we focus on the following research questions, specifically from the perspective of transportation IoT developers and manufacturers:

- RQ1: What are the dominant types of vulnerabilities in different categories of transportation IoT devices?
- RQ2: What are the CVSS severity scores of different categories of transportation IoT devices?
- RQ3: How do the CVSS Vectors (exploitability and impact metrics) compare between different categories of transportation IoT devices?

The main contributions of this paper include:

- We utilize the National Vulnerability Database (NVD) to extract and analyze information on security vulnerabilities in transportation IoT devices. Our empirical analysis allowed us to identify:
 - The dominant vulnerability classes across four categories of transportation IoT devices, and the most

frequent individual weaknesses.

- Median CVSS scores for each category of IoT device, along with attack vectors, scope, and impact metrics.
- We compile the lessons learned from our findings, along with actionable implications that can be used by both researchers and practitioners to efficiently improve the security of transportation IoT devices.

Several empirical studies have focused on security vulnerabilities in automobiles [6]–[9]. However, none of them consider the type of vehicle (i.e., EV vs Non-EV). In addition, we analyze two additional categories of devices: EV Chargers and Other Traffic Devices. A previous study [10] analyzed vulnerabilities on EV chargers. However, our study adds vulnerabilities and extends the analysis on to the CVSS scores and vectors of vulnerabilities, along with a comparison between categories of devices. To our knowledge, only our previous study [1] has been conducted on other types of IoT devices in the transportation domain, such as dash cameras, traffic controllers, and automotive microcontrollers.

Compared to our previous study [1], we include a larger sample of vulnerabilities (i.e., 1580 CVEs instead of 159) that now includes Qualcomm automotive microcontroller vulnerabilities (which were not included in [1]). We also conduct additional analysis of the CVSS Vectors, including the attack vectors, scope, and impact on Confidentiality, Integrity, and Availability (i.e., CIA) of the vulnerabilities.

This extension of [1] aims to discuss the generalizability of our previous study to a larger sample size, confirm previous assumptions and points that were discussed, and provide additional analysis of vulnerabilities. We provide additional insights as well as explain differences between the findings from the current and previous set of vulnerabilities. Lastly, we conduct deeper analysis on the exploitability and impact of vulnerabilities in each category.

This paper is organized as follows. Section II presents the related work. The methodology used in this study is detailed in Section III. The results related to dominant vulnerability classes are presented in Section IV, while Sections V and VI discuss the results of the analysis of CVSS scores and CVSS vectors respectively. Section VIII summarizes the lessons learned and actionable implications of our findings. The threats to validity are described in Section VII and the paper’s conclusions are in Section IX.

Transportation systems and devices are increasingly becoming connected to the Internet. Cars, traffic devices, and transportation systems have become integrated into the Internet of Things (IoT). As a result, they are parts of the critical infrastructure and are common targets of cyberattacks. Thus, the transportation industry was the eighth most common target of cyberattacks in 2023, accounting for 4.3% of the total cyberattacks [11]. The increasing use of connected technologies leads to more vulnerabilities that can be exploited by malicious adversaries, and thus a higher risk.

To better understand the risks associated with IoT transportation devices, this paper presents an empirical study on

security vulnerabilities in these devices. Specifically, we focus on studying security vulnerabilities that affect electric vehicle (EV) chargers, EVs, non-EVs, and other traffic devices that are connected to the Internet. We collect the CVEs related to transportation IoT devices from the NIST’s NVD [3] and from these CVEs extract the information about their specific individual vulnerabilities (i.e., CWEs), severity (i.e., CVSS scores and severity levels), and affected components. Then, following the approach introduced in [4], we group the individual CWEs into 23 vulnerability classes of the CWE-888 Software Fault Patterns view [5] with the goal of categorizing the security vulnerabilities. Furthermore, we analyze the associated CVSS scores, which integrate the exploitability and impact aspects of each security vulnerability.

This paper addresses the following research questions from the perspective of developers and manufacturers of transportation IoT devices:

RQ1: What are the dominant vulnerability classes in different categories of transportation IoT devices?

RQ2: What are the CVSS severity scores of different categories of transportation IoT devices?

The main contributions of this paper are:

- We extract information on security vulnerabilities associated with transportation IoT devices from NVD and conduct empirical analysis that allowed us to identify:
 - The dominant vulnerability classes for four different categories of transportation IoT devices, and the most vulnerable components in each category.
 - Typical CVSS severity scores for each category of IoT devices, and components that have vulnerabilities with high and critical severity levels.
- We compile the lessons learned and implications of our findings, and provide insights that can be used both by researchers and practitioners to improve the security of transportation IoT devices.

A few previous empirical studies focused on security vulnerabilities in vehicles [6]–[8], were published almost six years ago, and did not consider the type of vehicles (i.e., EVs and Non-EVs). In this study, we separately consider the EVs and Non-EVs categories of vehicles and present a more comprehensive analysis than prior works [6]–[8]. Furthermore, we explore the security vulnerabilities of two additional categories of transportation IoT devices – EV chargers and Other Traffic Devices¹ – for which, to the best of our knowledge, no previous empirical studies exist. Like [4], which was focused on mission-critical software, we use CWE-888 to group the vulnerabilities into 23 high-level vulnerability classes and subsequently to identify several dominant classes of vulnerabilities for each category of IoT devices. While [6]–[8] did discuss the CVSS scores of the vulnerabilities found in connected vehicles, we analyze the CVSS scores for the four categories of IoT devices and compare them, including testing

¹For Other Traffic Devices, we focused on devices that directly affect traffic and cars. Specifically, we considered the traffic controllers and their software, dash cameras, and automotive microcontrollers.

whether the differences are statistically significant. Finally, based on a comprehensive synthesis of our findings, we compile a list of lessons learned that identify overall patterns of security vulnerabilities in transportation IoT devices and provide actionable recommendations that can be useful for researchers and practitioners.

The paper is organized as follows. Section II presents the related works. The methodology used to conduct this study is explained in Section III. Section IV presents the results related to vulnerability classes, while Section V discusses the results of the analysis of CVSS scores. The lessons learned and the practical implications of our findings are summarized in Section VIII. The threats to validity are discussed in Section VII and the paper is concluded in Section IX.

II. RELATED WORK

Previous empirical studies of software vulnerabilities have been conducted in different domains, such as Android apps [12], [13], operating systems [14]–[16], mission critical software [4], embedded devices used in power grids [17], machine learning libraries [18], Python packages [19], and the Jupyter notebook ecosystem [20].

Related non-empirical works focused on the transportation domain include works by Saleem and Muhammad [21] on vulnerabilities in Electric Vehicle mobile applications, finding that there are a range of security weaknesses in multiple applications. Acharya et al. [22] also detailed vulnerabilities in EVs, EV chargers, and the power grid. Ronanki and Karneddi [23] focused on EV chargers and found that off-board and wireless chargers were the most vulnerable to cyberattacks. Anjana and Kumar [24] described vulnerabilities in EV charging infrastructure, including DDoS, malware injection, and charge manipulation, which can potentially cause blackouts through the power grid. Stichow and Rempel [25] developed a framework for authenticating electric vehicle drivers at EV charging stations. Nasr et al. [26] conducted a systemic analysis of EV Charging Station Management Systems (EVSMSs) and discovered vulnerabilities in the firmware, online applications, and web applications of EVCSMS. Shirvani et al. [27] developed a framework for assessing security during EV development involving five components: charging station security, information privacy, software security, connected vehicle security, and autonomous driver security. Johnson et al. [28] developed threat models and analyzed the risks of cyberattacks on EV charging infrastructure, and proposed an approach for securing them. Feng et al. [29] analyzed traffic signal control systems and found that the most realistic attack approach was data spoofing. Durlík et al. [30] studied vulnerabilities in autonomous vehicles, identifying several major threats such as remote hacking, sensor manipulation, data breaches, and DoS attacks. Jeong et al. [31] analyzed the impact of in-vehicle infotainment (IVI) system exploitation, and showed that lateral movement from infotainment to ECUs and smartphones was possible.

Related empirical studies on vulnerabilities in the transportation domain include [6]–[10], the first four of which focus

on connected vehicles while [10] focuses on EV charging stations. Basu and Staron [9] gathered automotive related vulnerabilities from NVD. They found that the most common attack vector for these vulnerabilities was SoC/Embedded system software. They also detailed the distribution of most common CWEs across the years 2018-2024. CWE-120 had the highest occurrences in one year, at 51 in 2019, while CWE-125 had the highest average occurrences in that period. For the severity of the vulnerabilities, the authors found that the majority were High severity. Xiong et al. [6] conducted an empirical study on vehicle vulnerabilities, both in EVs and Non-EVs. Using NVD, the authors found a total of 44 CVEs. In these, there were 21 unique CWEs related to the vehicles, the most common of which was Protection Mechanism Failure. This implies that protection mechanisms in these devices often have problems or are missing. Similarly to [9], they found that over half of the vulnerabilities were of high severity. They also found that 52% of the vulnerabilities had a Network attack vector. Kaya [7] conducted an empirical study on components of cars (both EV and Non-EV). Kaya found 211 vulnerabilities in these components, including Controller Area Network (CAN), Infotainment Systems, and Telematics Control Unit (TCU), through NVD. The most common CWE among the vulnerabilities was Protection Mechanism Failure with seven occurrences. Analysis of the distribution of CVEs among the components showed that 47% were related to the infotainment system and 39% were related to the Telematics system. The majority of vulnerabilities were also exploitable through the network, with a high impact on the vulnerable systems. Gülsever [8] studied vulnerabilities in connected EVs and Non-EVs with NVD, supplementing it with information on security incidents from Upstream Security. The components of vehicles that were most vulnerable included the infotainment system, mobile app, CAN, and TCU. He also found that 67.5% of the vulnerabilities could be exploited remotely. Plaka et al. [10] gathered information on EV charger vulnerabilities through IoT search engines, including ZoomEye and Fofa. They reported 81 vulnerabilities in popular charging station brands. The majority of the vulnerabilities were high severity, with only 3 Critical vulnerabilities. They also found that the most vulnerable technology on the stations was the Apache server, with 31 occurrences. In addition, after reporting the found vulnerabilities to a vendor, Mennekes, it was stated that “these systems should not be connected to the public internet.”

Prior empirical studies of software vulnerabilities were focused on different domains, such as Android apps [12], [13], operating systems [14], mission critical software [4], embedded devices used in power grids [17], machine learning libraries [18], and Python packages [19].

Related non-empirical works focused on the transportation domain included the work by Acharya et al. [22] which described the vulnerabilities that emerge from EVs, EV chargers, and the power grid. Ronanki and Karneddi [23] focused on EV chargers, and found that off-board and wireless chargers were the most vulnerable to cyberattacks, while on-board chargers

were the least vulnerable. Bhusal et al. [32] detailed the possible cyber-physical risks of smart charging management systems, such as data injection, man-in-the-middle, and DoS attacks. Pourmirza and Walker [33] gave recommendations on how to mitigate attacks against EV charging infrastructure. Nasr et al. [26] conducted a systemic analysis of EV Charging Station Management Systems (EVCSMSs) and discussed the implications. Muhammad et al. [34] discussed the security of mobile applications that manage EV usage. Shirvani et al. [27] developed a framework for assessing security during EV development and security profiling for EVs. Johnson et al. [28] developed threat models and analyzed the risks of cyberattacks on EV charging infrastructure, as well as proposed an approach for securing it. Feng et al. [29] provided an analysis framework for traffic signal control systems and found that the most plausible attack on these systems was data spoofing. Sharma and Gillanders [35] studied connected autonomous vehicles and their security challenges.

Only a few empirical studies on vulnerabilities in the transportation domain exist [6]–[8], and all were focused on connected vehicles. Xiong et al. [6] conducted an empirical study on vehicle vulnerabilities, investigating EVs and Non-EVs along with their connected components. Using the NVD’s “Keyword Search” they found a total of 44 CVEs. In these, there were 21 unique CWEs related to vehicles. They found that the most common CWE was Protection Mechanism Failure, implying that protection mechanisms often have problems or may be missing. In terms of CVSS metrics, they found that over half of the vulnerabilities were categorized as High severity. They also found that 52% of the vulnerabilities were able to be exploited remotely through the network. Kaya [7] studied connected automobiles, focusing on components of both EVs and Non-EVs and vulnerabilities affecting them (i.e., on Controller Area Network (CAN), Infotainment systems, and telematics control unit (TCU)). Kaya found 211 vulnerabilities related to these components through NVD. The most common CWE in these vulnerabilities was Protection Mechanism Failure with seven vulnerabilities. Kaya analyzed the component distribution and reported that 47% of them were related to the infotainment system and 39% were related to the TCU. Kaya found that the majority of vulnerabilities in these components and vehicles were exploitable through the network, and had a high impact on the systems they affect. Gülsever [8] studied vulnerabilities in connected cars (EVs and Non-EVs) using NVD, along with security incidents from Upstream Security. He found that 67.5% of these vulnerabilities could be exploited remotely. The components that had the most vulnerabilities associated with them were the infotainment system, mobile app, CAN, and TCU.

III. OUR METHODOLOGY

In this section, we detail the methodology used in this paper. The process is similar to the one used in our previous study [1], but with a few additional steps. First, we identified different brands of devices that belong to the four categories of transportation IoT devices. Using these brand names, we

collected the CVEs reported about them in NVD [3]. Second, we extracted the CVE data, including CWEs, CVSS scores, and CVSS Vectors. As in our previous study [1] and the earlier empirical study [4], we then grouped the individual CWEs into the primary classes of the CWE-888 view [5], allowing us to build a broad view of the most common types of vulnerabilities in these devices. After that, we analyzed the CVSS scores and vectors for each category.

Note that the empirical work presented in this paper follows the case study (i.e., observational) approach based on publicly available data in NVD that are entered and validated by experts and are widely used by researchers and practitioners. Using an experimental approach (e.g., conducting penetration testing) or a survey (e.g., collecting expert opinions) are complementary empirical approaches that are out of the scope of this paper.

In this section, we describe the methodology used in this paper. First, we identified different types of devices that belong to the four categories of transportation IoT devices and collected the CVEs reported about them in NVD [3]. Then, we extracted the CVEs’ characteristics, including the corresponding CWEs and CVSS information. Motivated by a previous study [4], we grouped the individual CWEs into primary clusters of the CWE-888 view [5] which allowed us to build a ‘big picture’ of security vulnerabilities in transportation IoT devices. We also analyzed the CVSS scores and severity levels for each category of IoT devices.

A. CVE collection

CVEs are publicly known security vulnerabilities that are attributed to specific software and hardware. The CVE program is managed by MITRE and enriched in NIST’s NVD. To collect CVEs related to vehicles and transportation IoT devices from NVD, we first identified companies and brands of these devices.

For EV Chargers, we identified brands and manufacturers using a list of charging station OEMs from Saascharge [36]. For EVs, we used a list of EV manufacturers eligible for tax credit from the IRS [37]. For the Non-EVs category, we obtained a list of major vehicle manufacturers from US News [38]. Lastly, for Other Traffic Devices, we included types of devices that directly affect traffic and cars. Among all these devices, we focused on automotive microcontrollers, traffic controllers and their software, dash cameras, fleet management software, transport cards, speed cameras/Automatic Number-Plate Recognition (ANPR), and pedestrian sensors. For each of these devices, we used a Google search to produce a list of companies that manufacture such device, then confirmed the information with subsequent searches. For Qualcomm microcontrollers, there are many CVEs, some of which affect automotive MCUs. In order to only include CVEs that affect them, we used names of automotive microcontrollers found on their website [39] and only included CVEs that affect at least one.

Exploration of the database VulDB [40] did not result in additional vulnerabilities for the devices in this paper. VicOne [41], the industry-specific database for automotive

vulnerabilities did have additional CVEs. However, some of them were unable to be identified as specifically related to EVs, Non-EVs, or Both. There were 17 of such vulnerabilities, which were excluded from our study.

We collected the CVE data from NVD until the end of July 2025. In total, there were 1580 different CVEs, broken down by category in Table I. In Figure 1 the distribution of CVEs by year is shown. Table II displays the number of CVEs by manufacturer. CVEs are publicly known security vulnerabilities that are reported in NVD [3] and attributed to specific software applications or libraries. In order to collect CVEs related to transportation IoT devices from NVD, we first had to identify the companies and corresponding brands and names of such devices. For EV charging stations, we identified the brands and names using the list of manufacturers provided by the Electric Drive Transportation Association [42]. For EVs, we collected the information from the IRS list of EV manufacturers eligible for tax credit [37]. **Note that peripheral devices, such as wireless OBD-II dongles [43], were not included in this study.** For Non-EVs, we identified the major vehicle manufacturers from the US News List of “All the Car Brands Available in America” [38]. For Other Traffic Devices category, we researched types of devices that directly affect traffic and cars, and then decided to focus on traffic controllers and their software, dash cameras, and automotive microcontrollers. For each of these, we used Google search to obtain a list of companies that produce that type of device and then ran queries to confirm the information. Note that CVE entries for Qualcomm products reported in NVD listed many chips. Since we were not able to confirm if these chips were related to automotive microcontrollers, we took a conservative approach and excluded all Qualcomm’s CVEs from the analysis. Note that studying intelligent road infrastructure devices, such as traffic signs, bus stops, and parking systems, is out of the scope of this paper.

We collected the data from NVD from January 2024 until April 2024. In total, we collected 159 CVEs, broken down per IoT device categories as shown in Table I. Figure 1 depicts how these CVEs were distributed over the years. (No vulnerabilities were reported for 2024 due to a backlog of vulnerabilities in NVD early that year.) Table ?? presents the names of the manufacturers associated with the 159 CVEs. (Open Charge Point Protocol was specifically referenced and is used by multiple manufacturers.)

TABLE I
CVEs AND CORRESPONDING CWES PER IoT DEVICE CATEGORY

Type	EV Chargers	EVs	Non-EVs	Other Traffic Devices	Total
CVEs	172	93	85	1231	1580
CWes	204	94	85	1510	1893

B. CWE and CVSS data extraction

Each CVE is typically linked to one or more CWes. However, 48 of the 1580 CVEs were not mapped to a CWE. This was because 34 did not have enough information to be associated with a CWE in the NVD and 14 were not in NVD’s



Fig. 1. Numbers of CVEs reported by year

CWE mapping [44]. As a result, these CVEs were included in our CVSS analysis but not in our CWE analysis. In total, 1893 CWes were associated to 1580 CVEs, the distribution being shown in Table I.

For each of the CVEs, we extracted additional CVSS information [1]. This includes CVSS scores, which range from 0 to 10 and are calculated based on the exploitability and impact of the vulnerability. The CVSS severity, which is based on the scores, were also extracted. Lastly, CVSS vectors were collected, which contain more in-depth information about the components. For example, metrics about the attack vector (Network, Adjacent, Local, Physical), attack complexity (Low, High), user interaction, and impact on confidentiality, integrity, and availability among other metrics. Each CVE is typically attributed to one or more CWes. However, some CVEs did not have enough information to be associated with CWE in the NVD or were not in NVD’s CWE mapping [44]. These CVEs are listed as NVD-CWE-noinfo and NVD-CWE-Other, respectively. Out of the total 159 CVEs, 22 were NVD-CWE-noinfo and two were NVD-CWE-Other. These 24 CVEs were included in our CVE analysis but did not contribute to our CWE analysis. In total, 149 CWes were associated with the 159 CVEs, broken down by IoT device categories as shown in Table I. These 149 CWes were actually attributed to only 57 unique CWes.

For each of the 159 CVEs, we also extracted the CVSS scores and vectors. CVSS scores range from 0 to 10 and are calculated based on the vulnerability’s exploitability and impact [45]. CVSS severity levels are based on the scores. Thus, 0 score indicates None severity level. Severity levels of Low, Medium, High, and Critical correspond to score ranges from 0.1 to 3.9, from 4.0 to 6.9, from 7.0 to 8.9, and from 9.0 to 10, respectively. **In addition to the CVSS**

TABLE II
CVEs DISTRIBUTION BY MANUFACTURER (SORTED BY NUMBER OF CVEs)

EV Chargers		EVs		Non-EVs		Other Traffic Devices	
Brand	CVEs	Brand	CVEs	Brand	CVEs	Brand	CVEs
Schneider Electric	34	Mercedes	27	Mercedes	29	Qualcomm	1093
Phoenix Contact	30	Tesla	26	Volkswagen	14	Q-Free	43
IoCharger	15	Volkswagen	14	BMW	8	NXP	14
Hardy Barth	15	BMW	7	Hyundai	6	Roav	11
Autel	15	Hyundai	6	Kia	4	STMicroelectronics	11
Open Charge Point Protocol	12	Toyota	4	Honda	4	Blackvue	7
CirControl	11	Renault	3	Nissan	4	AXIS	6
Enel X	11	BYD	1	Toyota	4	Renesas	5
ChargePoint	8	NIO	1	Chevrolet	2	Texas Instruments	4
GARO	5	Subaru	1	Suzuki	2	Microchip	4
Mennekes	5	Honda	1	BYD	2	Thinkware	4
UniFi Connect	3	Kia	1	Audi	1	Audi	4
ABB	2	Mitsubishi	1	Chrysler	1	Iteris	4
StarCharge	2	Suzuki	1	Mitsubishi	1	Cypress	3
Siemens	2			Subaru	1	Econolite	2
HomePlug	1					Infineon	2
Volkswagen	1					HID Global	2
						Selea	2
						FLIR	2
						SWARCO	1
						Yi Technology	1
						Fleetwire	1
						Assured Telematics	1
						DRD Fleet Leasing	1
						Fleetco	1
						Axper	1

scores and severity, we analyze the CVSS vectors that provide more information about the vulnerability. In this paper we use CVSS 3.X whose main fields include: the Attack Vector (AV), Scope (S), and impact metrics on Confidentiality, Integrity, and Availability (C, I, A). We prioritized the CVSS 3.X vectors as not all older CVEs have a CVSS 4.0 vector, while not all newer CVEs have a CVSS 3.X vector. Due to the fact that CVSS 3.X cannot be converted to CVSS 4.0 with the removal of metrics such as scope, we converted all CVSS 4.0 vectors back to CVSS 3.X. There were a total of 15 CVSS 4.0 vectors that we converted back for a comprehensive analysis. VC, VI, and VA, which represent the vulnerable system impact in CVSS 4.0 are equivalent to C, I, and A in CVSS 3.X. SC, SI, and SA, which represent the subsequent system impact in CVSS 4.0, on the other hand, have no direct equivalent in CVSS 3.X, so if any of the metrics were not None, we gave the Scope metric a value of Changed when converting back to CVSS 3.X.

Define and describe the Attack vectors and Scope as well.

Lastly, for each CVE, we manually extracted information about the vulnerable components from the CVEs' descriptions.

C. Mapping individual CWEs to the CWE-888 view

The CWE is a community-developed list of software and hardware weaknesses that is maintained by MITRE [46]. There are currently 944 weaknesses organized in a hierarchical structure. The CWEs at the highest level represent abstract weaknesses, with the weaknesses becoming more specifically tied to certain software and hardware further down in the hierarchy.

To navigate the complex CWE hierarchy, multiple CWE views have been developed (e.g., CWE-888 [5], CWE-699 [47]). For categorizing the weaknesses in transportation IoT devices, we selected the CWE-888 Software Fault Patterns view. This choice was made for two key reasons: first, it aligns with prior research [1], [4], enabling a direct comparison with our findings. Second, its focus on fault categorization provides a more technical and comprehensive view of weaknesses than other views such as CWE-699 [47], which is focused on development. CWE-699 only accounts for 399 CWEs while CWE-888 has 614.

In this paper, we use the most up-to-date version of CWE-888, which was last modified on September 9, 2025. We focus on the 23 primary clusters of CWE-888 and refer to them as primary vulnerability classes. If the CWE(s) identified through the process described in Section III-B are part of the CWE-888 view, we mapped them to their corresponding primary class. If not, we mapped them to their parent CWE's corresponding primary class. For example, CWE-798 Use of Hard-coded Credentials is not part of the CWE-888 view. We identified CWE-798's parents to be CWE-344 and CWE-671, which are in the CWE-888 view. These CWEs are in the Predictability primary class and Other primary class respectively, so CWE-798 would count towards both classes. In total, there were 20 CVEs with CWEs for which two parents were included in the CWE counts. On the other end, there were 395 CVEs that had more than one CWE listed. This approach allowed us to form a more comprehensive view of different types of vulnerabilities. Note that the CWE-888 Other primary class contains vulnerabilities related to Architecture, Compiler,

Design, or Implementation.

CWE is a community-developed taxonomy of common weaknesses which is maintained by MITRE [46]. Currently, there are 940 weaknesses organized in a hierarchical structure. The top-level CWEs represent broad vulnerability categories; the vulnerabilities become more specific further down into the hierarchy. Since the CWE hierarchical structure is complex, several CWE views (e.g., CWE-888 [5], CWE-699 [47]) have been developed. We chose the CWE-888 Software Fault Patterns view to categorize the identified CWEs related to transportation IoT devices for the following reasons: (i) it was used in [4], which allows consistency and direct comparison of results and (ii) it is focused on fault categorization. Thus, CWE-888 is more technical, and captures wider range of potential weaknesses than other views such as the CWE-699 Software Development view [47]. The CWE-888 view contains 614 CWEs while the CWE-699 view has 399 CWEs.

In this work, we use the most recent version of CWE-888, which was last updated on June 29, 2023. We focus only on the 23 primary clusters of CWE-888 and refer to them as primary vulnerability classes. If the CWE identified as described in Section III-B is a part of the CWE-888 view, we mapped it to the corresponding primary class. If not, we looked at its parent CWEs and mapped them to the CWE-888 view. For example, CWE-798 Use of Hard-coded Credentials is not in the CWE-888 view. Therefore, we identified the CWE-798's parents CWE-344 and CWE-671. These CWEs are in the CWE-888 view under the Predictability primary class and Other primary class respectively, making CWE-798 count towards both primary classes. There were only 10 CVEs (i.e., around 6%) with CWEs for which two parents were included in the CWE counts. This approach allowed us to build a more complete picture of different types of vulnerabilities while limiting over-counting the CWEs. On the other end, there were six CVEs that had two specific CWEs listed. For five of these, both CWEs were mapped to the same CWE-888 primary class, and only one was mapped to two different primary classes.

D. Analyses

Describe the analyses (included the stat tests used) with references to the sections where it is presented.

IV. RQ1: ANALYSIS OF VULNERABILITY CLASSES IN TRANSPORTATION IoT DEVICES

To answer RQ1, we refer to Tables III and IV, which show the numbers and percentages of CWEs mapped to the CWE-888 primary classes for the four categories and overall. Table III includes the Qualcomm vulnerabilities in the Other Traffic Devices category. Since over 75% of CWEs in this category were attributed to Qualcomm, we also provide Table IV, which excludes Qualcomm vulnerabilities.

To answer RQ1, we refer to Table ??, which shows the numbers and percentages of individual CWEs mapped to the 23 CWE-888 primary classes, for each of the IoT device categories and overall.

A. EV Charger vulnerabilities

Figure 2 shows the distribution of CWEs in EV Chargers across the primary classes. In total, there were 172 CVEs that mapped to 204 CWEs affecting EV charging stations and software. Among the 204 CWEs, there were 67 unique CWEs. The most common primary class was Tainted Input, accounting for 27% of the CWEs. The following top six common classes made up 77% of the EV Charger vulnerabilities: Tainted Input, Authentication (15%), Memory Access (13%), Information Leak (10%), Privilege (6%), and Access Control (6%). Authentication (30%), Tainted Input (19%) and Information Leak (17%) were among the most frequent vulnerability categories in our previous work as well [1].

The most common single CWE for EV Chargers was CWE-78: OS Command Injection [48]. There were 22 vulnerabilities with CWE-78, 10 of which from Iocharger stations. CWE-78 refers to a software that uses external input to construct part of an OS command, but doesn't properly neutralize components that may be able to modify the intended command. An example of this is CVE-2024-43657, which allows attackers to gain full control of the Iocharger station by uploading a crafted firmware file to it or convincing a user to do so.

Previous research has shown many dangerous impacts of vulnerabilities in EV chargers. For example, CVE-2024-43659 showed that Iocharger AC model EV chargers all had the same default credentials, allowing attackers to gain full control over the device if connected to the Internet. This allows for actions such as starting and ending charging sessions, changing the charging rate, and other actions possible on the hardware. In addition, blackouts and disruptions in the power grid through EVCS are becoming more likely as EVs become more common [24]. If attackers were in control of a botnet of EV charging stations, they could synchronize charging and discharging, causing large disruptions in the power grid [49].

Figure 2 shows the distribution of EV chargers' CWEs across CWE-888 primary classes. There were 49 CVEs that corresponded to 54 CWEs that affected EV charging stations or EV charger software. There were 27 unique CWEs among the 54 total, covering 10 of the 23 primary classes. The most common class was Authentication with 30% of the CWEs. The following top six classes made up 89% of all EV charger vulnerabilities: Authentication, Tainted Input, Information Leak, Predictability, Other, and Channel (see Table ??).

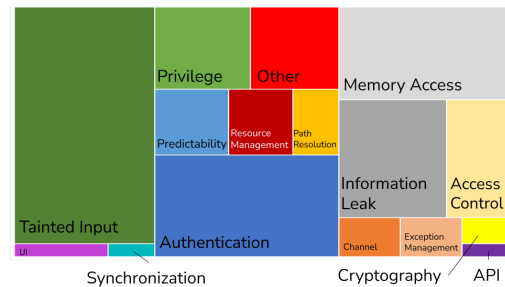


Fig. 2. Distribution of EV chargers' vulnerabilities across the primary classes

B. EV vulnerabilities

TABLE III
DISTRIBUTION OF VULNERABILITIES ACROSS PRIMARY CLASSES FOR EACH IoT CATEGORY (INCLUDING QUALCOMM)

Primary CWE-888 Class	EV Chargers	EVs	Non-EVs	Other Traffic Devices	All
Access Control	12 (6%)	9 (10%)	9 (11%)	57 (4%)	88 (5%)
API	1 (0%)			44 (3%)	45 (2%)
Authentication	31 (15%)	8 (8%)	10 (12%)	48 (3%)	96 (5%)
Channel	4 (2%)	3 (3%)	6 (7%)	1 (0%)	14 (0.7%)
Cryptography	2 (1%)	4 (4%)	2 (2%)	5 (0.3%)	13 (0.7%)
Entry Points					
Exception Management	4 (2%)	3 (3%)	2 (2%)	15 (1%)	24 (1%)
Failure to Release Memory				7 (0.5%)	7 (0.4%)
Faulty Resource Release				24 (2%)	24 (1%)
Information Leak	21 (10%)	6 (6%)	5 (6%)	32 (2%)	64 (3%)
Malware				19 (1%)	19 (1%)
Memory Access	26 (13%)	17 (18%)	12 (14%)	870 (58%)	925 (49%)
Memory Management			1 (1%)		1 (0.1%)
Other	12 (6%)	10 (11%)	10 (12%)	13 (1%)	45 (2%)
Path Resolution	5 (2%)	2 (2%)	1 (1%)	9 (1%)	17 (1%)
Predictability	8 (4%)	3 (3%)	3 (3%)	9 (1%)	23 (1%)
Privilege	13 (6%)	4 (4%)	3 (4%)	3 (0.2%)	23 (1%)
Resource Management	7 (3%)	5 (5%)	4 (5%)	123 (8%)	139 (7%)
Risky Values		9 (10%)	8 (10%)	113 (8%)	130 (7%)
Synchronization	1 (0%)	3 (3%)		33 (2%)	37 (2%)
Tainted Input	55 (27%)	8 (8%)	9 (11%)	85 (6%)	157 (8%)
UI	2 (1%)				2 (0.1%)
Unused Entities					
Total of 6 Most Common	158 (77%)	61 (65%)	58 (68%)	1296 (86%)	1535 (81%)
Total	204	94	85	1510	1893

TABLE IV
DISTRIBUTION OF VULNERABILITIES ACROSS PRIMARY CLASSES FOR EACH IoT CATEGORY (EXCLUDING QUALCOMM)

Primary CWE-888 Class	EV Chargers	EVs	Non-EVs	Other Traffic Devices	All
Access Control	12 (6%)	9 (10%)	9 (11%)	26 (17%)	57 (11%)
API	1 (0.5%)				1 (0.1%)
Authentication	31 (15%)	8 (8%)	10 (12%)	30 (19%)	78 (15%)
Channel	4 (2%)	3 (3%)	6 (7%)	1 (1%)	14 (3%)
Cryptography	2 (1%)	4 (4%)	2 (2%)	3 (2%)	11 (2%)
Entry Points					
Exception Management	4 (2%)	3 (3%)	2 (2%)	5 (3%)	14 (3%)
Failure to Release Memory					
Faulty Resource Release					
Information Leak	21 (10%)	6 (6%)	5 (6%)	14 (9%)	46 (9%)
Malware				19 (12%)	19 (4%)
Memory Access	26 (13%)	17 (18%)	12 (14%)	11 (7%)	66 (12%)
Memory Management			1 (1%)		1 (0.1%)
Other	12 (6%)	10 (11%)	10 (12%)	5 (3%)	37 (7%)
Path Resolution	5 (2%)	2 (2%)	1 (1%)	9 (6%)	17 (3%)
Predictability	8 (4%)	3 (3%)	3 (3%)	4 (3%)	18 (3%)
Privilege	13 (6%)	4 (4%)	3 (4%)	3 (2%)	23 (4%)
Resource Management	7 (3%)	5 (5%)	4 (5%)	5 (3%)	21 (4%)
Risky Values		9 (10%)	8 (10%)	2 (1%)	19 (4%)
Synchronization	1 (0.5%)	3 (3%)		2 (1%)	6 (1%)
Tainted Input	55 (27%)	8 (8%)	9 (11%)	15 (10%)	87 (16%)
UI	2 (1%)				2 (0.1%)
Unused Entities					
Total of 6 Most Common	158 (77%)	61 (65%)	58 (68%)	115 (75%)	371 (69%)
Total	204	94	85	154	537

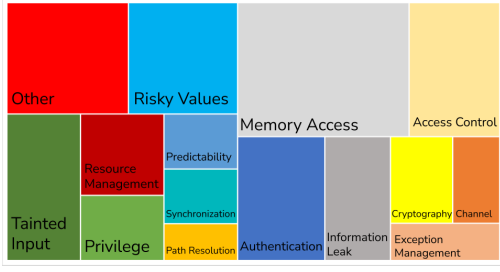


Fig. 3. Distribution of EVs' vulnerabilities across the primary classes

Figure 3 shows the distribution of CWEs in EVs across the primary classes. In total, there were 93 CVEs that mapped to 94 CWEs. Among the 94 CWEs, there were 46 unique CWEs. The most common primary class was Memory Access, accounting for 18% of the CWEs. The following top six common classes made up 65% of the EV vulnerabilities: Memory Access, Other (11%), Access Control (10%), Risky Values (10%), Tainted Input (8%), and Authentication (8%). Memory Access (21%), Other (18%), and Tainted Input (11%) were among the most frequent vulnerability classes in Yih as well.

The most common CWE was CWE-693 Protection Mechanism Failure, which is consistent with the results found in [1], [6]–[8]. CWE-693 describes a product that either does not use or incorrectly uses a protection mechanism that is intended to defend against attacks [50], and all of these vulnerabilities were in BMW i Series and X Series EVs.

There are many dangerous attacks shown to be possible on EVs. For example, the Tencent Keen Security Lab remotely gained root privilege of a Tesla infotainment system and was able to take control of the vehicle itself [51]. In addition, during the automotive hacking competition, Pwn2Own, it was shown that Tesla gateway ECUs could be hacked and used to transmit arbitrary CAN bus messages. This can result in attackers seizing control of the vehicle functions, disrupting safety systems, and even stealing the vehicle itself. In real-world situations, replay attacks are very common. For example in 2025, Hyundai Ioniq 5 vehicles were vulnerable to replay attacks by emulator devices that could simply send a signal to unlock the car [52].

Figure 3 shows the distribution of EVs' CWEs across CWE-888 primary classes. There were 46 CVEs that corresponded to a total of 38 CWEs. This is due to the fact that 8 CVEs were NVD-CWE-noinfo, i.e., were missing a CWE number. There were 24 unique CWEs among the 38 total. The EV vulnerabilities belonged to 13 out of the 23 primary classes. 21% of the vulnerabilities belonged to the Memory Access primary classes, which was the most common in this category. The top six primary classes accounted for 74% of the total vulnerabilities. They were Memory Access, Other, Tainted Input, Channel, Cryptography, and Privilege. The most common individual CWE was CWE-693 Protection Mechanism Failure, which is consistent with the results reported in [6]–[8]. In our dataset, all CWE-693 vulnerabilities were related to BMW's i Series and X Series EVs. CWE-693 refers to a product that

either does not use or incorrectly uses a protection mechanism that is intended to defend against attacks [50]. One example of a protection mechanism failure is CVE-2018-9322 [53], where attackers could bypass the code-signing protection mechanism for firmware updates on BMWs to obtain a root shell.

C. Non-EV vulnerabilities

Figure 4 shows the distribution of CWEs in Non-EVs across the primary classes. In total, there were 85 CVEs that mapped to 85 CWEs, among which 47 were unique CWEs. The most common primary class was Memory Access, accounting for 14% of the CWEs. The following top six common classes made up 68% of the Non-EV vulnerabilities: Memory Access, Other (12%), Authentication (12%), Access Control (11%), Tainted Input (11%), and Risky Values (10%). Consistently with this study, Other (13%), Authentication (12%), and Tainted Input (12%) were among the most dominant vulnerability categories in [1]. On the other hand, Channel vulnerabilities were more frequent in [1] compared to this study (i.e., 29% vs. 7%).

Similar to EVs, the most common CWE for Non-EVs was CWE-693 Protection Mechanism Failure. All of these vulnerabilities were in BMW's 3 Series vehicles.

The dangers of Non-EV attacks are very similar to those of EVs. For example, it was showed that attackers can potentially cause car accidents by compromising the infotainment system of vehicles and disrupting the functions of the vehicle [31]. In addition, attackers can obtain personally identifiable information (PII) from the infotainment system, including location, phonebook information, text messages, and more.

Figure 4 displays the distribution of Non-EVs' CWEs across the primary classes. There were a total of 28 CVEs with 24 total CWEs, among which there were 11 unique CWEs. Note that 5 CVEs were classified as NVD-CWE-noinfo. The Non-EV vulnerabilities covered 9 primary classes out of 23. The most dominant class was Channel with 29% of all vulnerabilities in this category. The top six primary classes accounted for 83% of the vulnerabilities for the Non-EVs. They were Channel, Authentication, Other, Tainted Input, Access Control, and Predictability. The most common individual CWE for Non-EVs was CWE-294 Authentication Bypass by Capture-replay. This vulnerability was not reported in [6]–[8], which is understandable having in mind that the CVEs with CWE-294 vulnerability were reported after the publication of [6]–[8]. CWE-294 describes a vulnerability that makes it possible for a malicious user to capture a signal used in the product and replay it to the receiver, resulting in the same or similar effect [54]. An example of this is CVE-2022-37305 [55], for which the remote keyless system of a Honda vehicle allowed attackers to unlock the car indefinitely after capturing five consecutive valid signals.

D. EVs vs. Non-EVs vs. Both

It should be noted that many CVEs affected both EVs and Non-EVs, and therefore they were counted in both categories in Tables III and IV. The breakdown of CWEs across EVs,

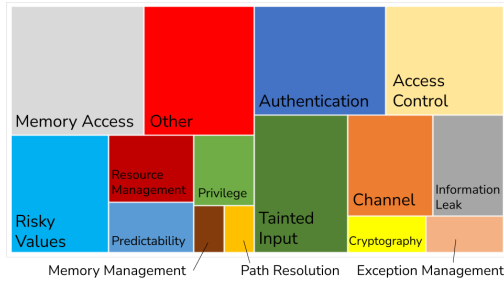


Fig. 4. Distribution of Non-EVs's vulnerabilities across the primary classes

TABLE V
DISTRIBUTION OF CWES ACROSS EVs, NON-EVs, AND BOTH

Primary CWE-888 Class	EVs	Non-EVs	Both
Access Control	2 (7%)	2 (11%)	7 (11%)
Authentication	2 (7%)	4 (22%)	6 (9%)
Channel	2 (7%)	5 (28%)	1 (2%)
Cryptography	2 (7%)		2 (3%)
Information Leak	1 (4%)		5 (8%)
Memory Access	6 (22%)	1 (6%)	11 (17%)
Memory Management		1 (6%)	
Other	1 (4%)	1 (6%)	9 (14%)
Path Resolution			2 (3%)
Predictability	1 (4%)	1 (6%)	2 (3%)
Privilege	1 (4%)		3 (5%)
Resource Management	1 (4%)		4 (6%)
Risky Values	1 (4%)		8 (13%)
Synchronization	3 (11%)		
Tainted Input	4 (15%)	3 (17%)	4 (6%)
Total of 6 Most Common	19 (70%)	16 (88%)	46 (69%)
Total	27	18	67

Non-EVs, and both categories is shown in Table V. The top six vulnerability classes in the three categories accounted for 70%, 88%, and 69% of the total CWEs, respectively. In all three categories, Access Control, Authentication, and Memory Access were among the six most common primary classes. For EVs and Both, Memory Access was the most common primary class. The Memory Access CWEs for EVs belonged to CWE-787 Out of Bounds Write, CWE-120 Classic Buffer Overflow, and CWE-122 Heap-based Buffer Overflow. These CWEs contributed to 64% of CWEs that affected Both EVs and Non-EVs and the rest were due to CWE-121 Stack-based Buffer Overflow.

E. Other Traffic Devices vulnerabilities

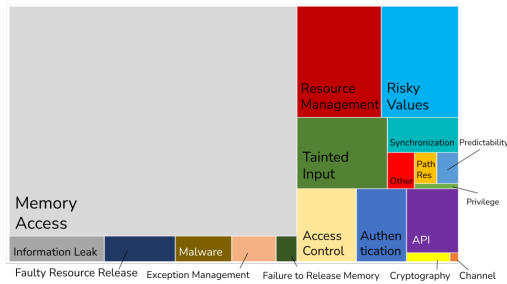


Fig. 5. Distribution of Other Traffic Devices' vulnerabilities across the primary classes

Figure 5 shows the distribution of CWEs in the Other Traffic Devices category across the primary classes. In total,

there were 1,231 CVEs that mapped to 1,510 CWEs, among which 100 were unique CWEs. The most common primary class was Memory Access, consisting of 58% of the CWEs. The following top six common classes made up 86% of the Other Traffic Device vulnerabilities: Memory Access, Resource Management (8%), Risky Values (8%), Tainted Input (6%), Access Control (4%), and Authentication (3%). Memory Access (33%), Access Control (18%), and Authentication (15%) were among the dominant classes in [1] as well. (Note that the sample size of Other Traffic Devices in [1] was only 33.)

The most common CWE in this category was CWE-125 Out-of-Bounds Read. In total, 210 out of the 1,510 CWEs were CWE-125. Of these, 208 were in Qualcomm automotive chips among which CWE-125 was the most vulnerability. Other common individual CWEs in this category included CWE-787 Out-of-Bounds Write, CWE-416 Use After Free, CWE-190 Integer Overflow or Wraparound, and CWE-20 Improper Input Validation with 182, 108, 71 and 70 instances, respectively.

Table IV displays the distribution of CWEs in the Other Traffic Devices category without Qualcomm vulnerabilities. In total, there were 154 CWEs, 60 of which were unique. The most common primary class was Authentication, making up 19% of the CWEs. The six most common classes, are Authentication, Access Control, Malware, Tainted Input, Information Leak, and Memory Access.

The impact of vulnerabilities in Other Traffic Devices is prominent because automotive microcontrollers are used in vehicles to control different critical systems such as the powertrain, airbags, etc. In addition, it has been shown that dash cameras are exploitable allowing attackers to retrieve GPS, driver, and car information, along with audio and video footage [56].

Figure 5 shows the distribution of vulnerabilities that affected the Other Traffic Devices (i.e., automotive microcontrollers, traffic controllers and their software, and dash cameras) across the primary classes. There were 36 CVEs that corresponded to 33 total CWEs. Five CVEs were classified as NVD-CWE-noinfo. 22 unique CWEs were associated with the 33 total CWEs. These belonged to 9 out of the 23 total primary classes. The most common was Memory Access, which consisted of 33% of the vulnerabilities in this category. The 6 most common classes were Memory Access, Access Control, Authentication, Information Leak, Cryptography, and Other. In total, they accounted for 88% of all vulnerabilities in this category.

V. RQ2: ANALYSIS OF CVSS SCORES AND SEVERITY

Box plots of the CVSS scores for the four categories of transportation IoT devices are shown in Figure 6. The results showed that EV Chargers and Other Traffic Devices categories had the same median score of 7.8. For EV Chargers, this high median score was due to many critical CVEs. For example, CVE-2023-46359, which had a CVSS score of 9.8, allows attackers to inject arbitrary commands into the web server of Hardy Barth charging stations. As shown by researchers

at Offensity [57] this vulnerability enables attackers to gain administrator privileges, monitoring and managing charging usage, logs, and firmware updates among other things. Circontrol EV chargers were linked to another CVE with a score of 9.8 (i.e., CVE-2018-12634) that allows attackers to remotely obtain sensitive information via a direct request to the web server. **Many other PoCs for exploits in these chargers in [58].**

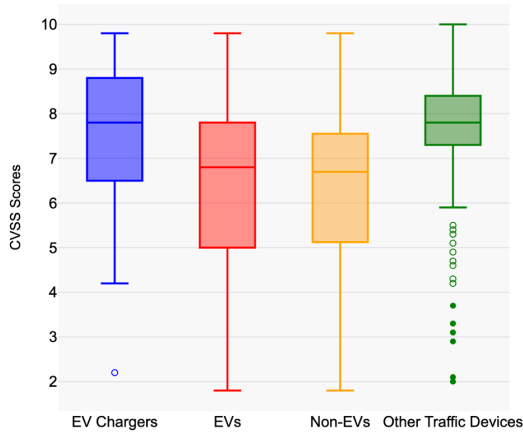


Fig. 6. Box plots of CVSS scores across the four categories

Similarly to EV chargers, the high median score for Other Traffic Devices was due to many CVEs that had critical severity. For example, CVE-2025-26359 is a vulnerability in Q-Free MaxTime traffic controllers that allows unauthenticated attackers to remotely reset user PINs in the devices. This brings the possibility of attackers gaining administrative access to the traffic controllers, being able to change timings and phases to disrupt traffic. It would also be possible to shut down major intersections by setting lights to red or yellow.

The CVSS scores of EVs and Non-EVs were similar, with median scores of 6.8 and 6.7, respectively. This is likely due to shared CVEs that appeared in both categories (see Table V). CVE-2022-23126 is an example of a critical CVE associated with the TeslaMate app. It allowed attackers to open Tesla doors, start Keyless driving, and interfere with the operation of the vehicle. For Non-EVs there were no critical CVEs. Most vulnerabilities that only affected Non-EVs, such as CVE-2020-5551, had a limited impact on critical vehicle controls and required sophisticated knowledge of the vehicle.

We conducted a Kruskal-Wallis test to determine if the CVSS scores of transportation IoT categories were statistically significant different. The p-value of 3.26×10^{-24} showed that there is a significant difference. The results of Dunn's post hoc test, shown in Table VI, revealed that both the EV Chargers and Other Traffic Devices categories indeed had statistically significantly different CVSS distributions from EVs and Non-EVs.

Figure 7 shows the distribution of CVEs among the four severity classes: Critical, High, Medium, and Low. **Jason, define the severity classes (based on scores) and discuss add 1-2 sentences of the results presented in Figure 7.**

In this section, we analyze the CVSS scores (shown in Figure 6) and CVSS severity levels (presented in Figure 7)

TABLE VI
DUNN'S TEST P-VALUES

Dunn's Test	EV Chargers	EVs	Non-EVs	Other Traffic
EV Chargers	1	2.34×10^{-8}	2.92×10^{-11}	0.75
EVs	2.34×10^{-8}	1	0.33	1.53×10^{-12}
Non-EVs	2.92×10^{-11}	0.33	1	6.30×10^{-17}
Other Traffic	0.75	1.53×10^{-12}	6.30×10^{-17}	1

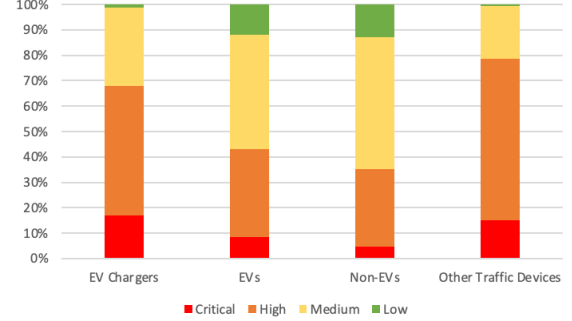


Fig. 7. CVSS severity classes across the four categories

for the four categories of transportation IoT devices). The CVSS score ranges from 0 to 10 and is a composite metric that integrates the exploitability metrics and impact metrics (i.e., the consequences of successful exploits), and combines them with the temporal and environmental factors [45].

The mean CVSS severity score for the EV Chargers category was 7.87. The most common components that CVEs were associated with were the web interface, web server, and communication protocol of the EV charger. The EVs category had a mean CVSS score of 7.32. The components with the most vulnerabilities were the infotainment system, Remote Keyless Entry (RKE) system, mobile apps used to control the car, and Telematics Control Unit (TCU). Note that the prior work [7] listed only the infotainment and TCU as the most vulnerable components. In addition to those, our results showed that mobile apps and RKE systems were among the most vulnerable components in the EVs and Non-EVs categories. The mean CVSS score of the Non-EVs category was 5.93. Similar to EVs, the most vulnerable components were the infotainment system, RKE, mobile app, and TCU. The Other Traffic Devices category had a mean CVSS score of 7.66. Among the multiple types of devices in this category, the most CVEs were associated with the automotive microcontrollers, followed by dash cameras.

Figure 7 shows the distribution of the CVEs among the four CVSS severity classes, for the four categories of transportation IoT devices. Furthermore, Table ?? provides the numbers of critical and high severity vulnerabilities associated with each of the most vulnerable components, which are further discussed in Section VIII.

VI. RQ3: ANALYSIS OF CVSS VECTORS

The distribution of CVEs among the Attack Vector values is shown in Figure 8. It can be seen that for EV Chargers and Other Traffic Devices categories around 65% of vulnerabilities are exploitable through the network. On the other hand, CVEs

for EVs and Non-EVs are fairly evenly distributed among the Network, Adjacent, Local, and Physical categories.

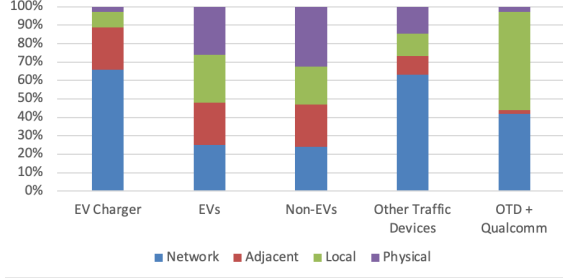


Fig. 8. Attack Vectors across the four IoT device categories

The distribution of CVEs across Scope is shown in Figure 9. A value of Changed, which represents an exploit that is able to cause damage outside of the original scope, was the highest for the EV Chargers category, at about 13% of CVEs. Other Traffic Devices had the second highest Change scope, at approximately 8.7%, while the EV and Non-EV categories had about 4-5% of CVEs with a Changed scope.

Lastly, the impact metrics of CVEs in each category are shown in Figures 10 (a)-(d). Each CVE can affect Confidentiality, Integrity, Availability, or any combination of the three. In every category, over 40% of CVEs affected all three security attributes. OTD+Qualcomm had the highest proportion of vulnerabilities affecting all three, with 62%. EV Chargers had the second highest proportion at 58%, while the other 3 categories each had about 42-48% of CVEs that impacted all three metrics. EVs and Non-EVs had a high percentage of CVEs that affected only Confidentiality and only Availability. In addition, about 20% of Other Traffic Devices CVEs affected only Confidentiality, showing that many vulnerabilities in this category aim to gain unauthorized access to data.

VII. THREATS TO VALIDITY

Construct validity relates to the ability to measure what we intend to evaluate. We utilized NIST’s NVD and MITRE’s CWE, which are widely used by the industry and for similar empirical studies. We also applied the data triangulation principle and search additional sources such as VulDB [40] and VicOne [41], which did not lead to additional CVEs. Out of the 1,580 total CVEs extracted for this study, 34 did not have enough information to be attributed to a CWE. An additional 14 CVEs were NVD-CWE-Other and as a result could not be classified as one of the existing CWEs. Therefore, these 48 CVEs were excluded from the CWE analysis. Some CVEs were had multiple root causes (CWEs). To capture this information, all CWEs were included in the relevant CWE analysis. In order to conduct a comprehensive study, we searched for many manufacturers of the categories of devices included in the study. However, for many of them no CVEs were reported in NVD. Despite our systematic search for manufacturers, it is possible that some lesser-known manufacturers were overlooked, leading to a potential sampling bias. In addition, in case of the Other Traffic Devices, the majority of CVEs were attributed to Qualcomm devices,

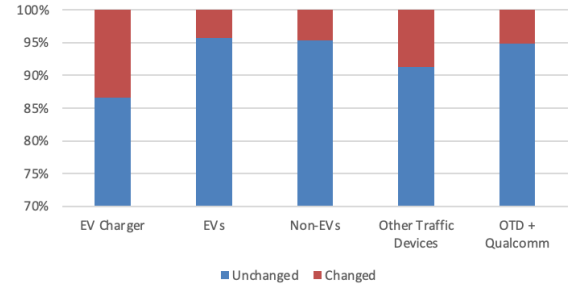


Fig. 9. Scope across the four IoT device categories

which skewed the results towards that company. To mitigate this treat, we conducted analyses of Other Traffic Devices both with and without the Qualcomm’s related CVEs.

Internal validity is related to the influence of external factors that may affect the results without the researchers’ knowledge. The quality of the extracted data depends on the quality and completeness of information provided in our data sources. Since both NVD and CWE are widely used and trusted by both researchers and practitioners provide some assurance of the data quality. This study, as any other empirical study that relies on publicly available information, cannot account for undisclosed vulnerabilities and zero-day vulnerabilities.

Conclusion validity is related to the ability to draw correct conclusions. One threat to conclusion validity is the sample size of the data. The total sample size in this study is 1,580 CVEs, which are much larger than in our previous study [1] and other studies on transportation IoT devices. Even though the EVs and Non-EVs categories had less CVEs (i.e., 93 and 85 CVEs, respectively) compared to the other two categories, their sample sizes were large enough to conduct the analyses, including using statistical tests with sufficient power. Another threat to conclusion validity is related to the statistical tests being used. In this study, we used the appropriate non-parametric tests because our data were not normally distributed.

External validity focuses on generalizability. IoT devices considered in this study were produced by different manufacturers, from different countries (see Table II), which supports generalizability. Furthermore, both the number of device manufactures and the sample size in this study are significantly bigger than in [1], thus allowing for exploration of generalizability. Nevertheless, our results only apply to the categories of transportation IoT devices considered in this paper and cannot be generalized to other types of IoT devices or other domains. Future empirical research focused on IoT devices used in other domains can further explore the generalizability of the findings presented in this paper.

Construct validity relates to the ability to measure what we intend to evaluate. As in other studies on security vulnerabilities, we searched for information on NIST’s NVD and MITRE’s CWE, which are widely used. Close exploration of the Vulnerability Database VulDB [40] did not result in additional vulnerabilities for the devices considered in this

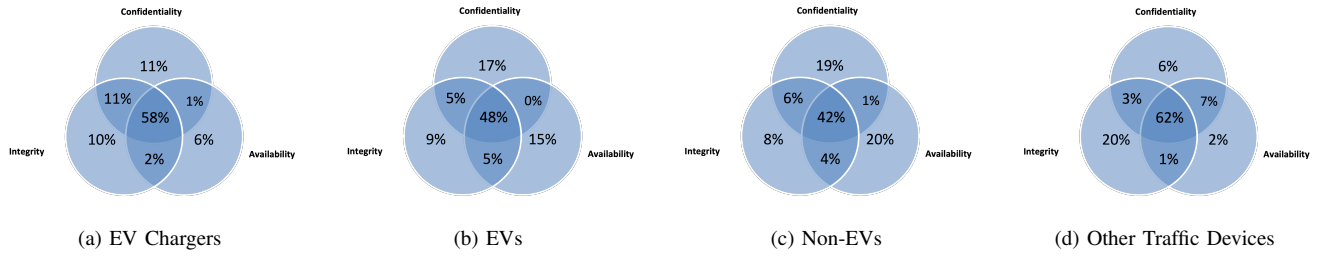


Fig. 10. Affected security attributes for different categories of transportation IoT devices

paper. However, there are industry-specific databases such as VicOne [41] and Upstream [59] that may provide additional information on automotive vulnerabilities, which we plan to explore in our future work. Twenty two (out of 159) CVEs did not provide the corresponding CWE numbers. Two additional CVEs were in NVD-CWE-Other and therefore could not be classified as one of the existing CWEs. These 24 CVEs were excluded from the CWE analysis. In an attempt to extract comprehensive data, we searched for many manufacturers of EV chargers, EVs, Non-EVs, and other traffic devices, but for many of them, there were no CVEs reported. Even though we did a thorough search for manufacturers (see section III-A), it is possible that some less-known manufacturers were overlooked, which may have resulted in some sampling bias. On the other side, some companies such as Schneider Electric for EV chargers and Tesla for EVs had many CVEs reported for their products which skewed the results towards these companies.

Internal validity is based on factors that may affect the independent variables without the researchers' knowledge. The quality of the extracted data depends on the quality and completeness of the information reported in NVD and CWE, and therefore consist an internal threat to validity. However, both NVD and CWE are widely used and trusted by researchers and practitioners alike. As with any other empirical study of vulnerabilities, it is not possible to account for undisclosed vulnerabilities and zero-day vulnerabilities.

Conclusion validity threats impact the ability to draw correct conclusions. The data sample size may affect the conclusion validity. The results presented in this paper are based on an analysis of 159 CVEs and the associated 149 CWEs, which constitute a fairly large sample. In spite of our effort to extract an exhaustive sample of vulnerabilities for transportation IoT devices, the analyses per IoT device category were based on smaller sample sizes (from 24 to 54 CWEs) which poses a threat to the conclusion validity.

External validity is focused on the generalizability. Our results only apply to the type of transportation IoT devices and vehicles covered in this paper. As can be seen in Table ??, these IoT devices have been produced by different manufacturers, from different countries. The results, however, cannot be generalized to all IoT devices or other domains. Future empirical studies focused on additional transportation IoT devices and vehicles, as well as other domains can be conducted to further explore the generalizability of our

findings.

VIII. LESSONS LEARNED AND IMPLICATIONS

Our main findings about the vulnerabilities related to vehicles and transportation IoT devices are as follows.

The top six primary classes (out of 23) accounted for 81% of all vulnerabilities. This finding proves the generalizability of the observation that the distribution of vulnerabilities is highly skewed across only a small number of primary classes [1], [4], [14]–[16]. In this study, Memory Access alone accounted for 49% of all CWEs, followed by Tainted Input (8%), Resource Management (7%), Risky Values (7%), Access Control (5%), and Authentication (5%).

In each category, the six most common primary classes accounted for 65% to 86% of all reported vulnerabilities. Specifically, EV chargers, EVs, Non-EVs, and Other Traffic Devices had 77%, 65%, 68%, and 86% of their vulnerabilities in the top six primary classes for their category, respectively. This finding is consistent with the results in our previous study [1], which had from 74% to 89% of the total vulnerabilities in each category distributed among the top six classes.

The most common vulnerability classes for EV Chargers were Tainted Input (27%), Authentication (15%), Memory Access (13%), Information Leak (10%), Access Control (6%), and Privilege (6%). This indicates that EV Chargers most often have problems with injection attacks, input validation, insecure passwords, insufficient authentication, out-of-bounds reads and writes, and buffer overflows. Thus, 67% of Tainted Input CWEs were due to OS Command Injection (CWE-78), Command Injection (CWE-77) and Cross-site Scripting (CWE-79). With regards to the attack vector, about 65% of CVEs in EV Chargers could be exploited through the Network, which is due to the fact that they are typically accessible on the Internet [60]. In addition, EV Chargers had the greatest percentage of CVEs affecting components outside of the scope of the original vulnerability (i.e., 13%). For example, exploits of charging stations may affect and disrupt the power grid behind it [24].

The most common vulnerability classes for EVs were Memory Access (18%), Other (11%), Access Control (10%), Risky Values (10%), Authentication (8%), and Tainted Input (8%). The most common individual CWE in EVs was CWE-693 Protection Mechanism Failure from the Other primary class (under Architecture secondary class). This

vulnerability indicates lack of or incorrect usage of protection mechanisms against attacks. The second most common CWE was CWE-190 Integer Overflow or Wraparound, which occurs when an integer is incremented to a value that is too large to store in the associated representation. It belongs to the Risky Values class. The Memory Access class was dominated by CWEs related to writing data outside of the bounds of memory buffers, indicating the persistence of buffer overflow vulnerabilities in EVs. Examples include six CWE-787 Out-of-bounds Write, four CWE-122 Heap-based Buffer Overflow, and two CWE-120 Classic Buffer Overflow. Attack vectors were approximately evenly split between Network, Adjacent, Local, and Physical, which demonstrates many potential points of attacks for EVs.

The most common vulnerability classes for Non-EVs were the same as for EVs: Memory Access (14%), Other (12%), Authentication (12%), Access Control (11%), Tainted Input (11%), and Risky Values (10%). Similar to EVs, many of the Memory Access vulnerabilities were due to out-of-bounds writes and buffer overflows. For the Other primary class, seven CWEs were Protection Mechanism Failure (CWE 693) and two were Use of Hard-coded Credentials (CWE 798). Five of the 8 Risky Values vulnerabilities were CWE-190 Integer Overflow or Wraparound. As in case of EVs, the attack vectors were relatively evenly divided among the four types, with slightly more Physical attacks at about 33%.

The most common vulnerabilities for Other Traffic Devices were Memory Access (58%), Resource Management (8%), Risky Values (8%), Tainted Input (6%), Access Control (4%), and Authentication (3%). Memory Access, which dominated overall, had a large percentage of CWEs related to reading out-of-bounds, consistent with [9]. This included 210 occurrences of CWE-125 Out-of-bounds Read and 119 of CWE-126 Buffer Over-read. Significant portion was also related to writing to memory out-of-bounds, including 182 occurrences of CWE-787 Out-of-bounds Write and 144 occurrences of CWE-120 Classic Buffer Overflow. For the Resource Management class, 108 of the 123 vulnerabilities were CWE-416 Use After Free, all of which were reported for the Qualcomm automotive microcontrollers. The Risky Values class contained 71 CWE-190 Integer Overflow or Wraparound CWEs. With regards to the attack vectors, 42% were Network related. When Qualcomm CVEs were excluded, about 63% of CVEs were related to Network attacks. This is because a Local attack vector was more common among Qualcomm devices, with over 53% of CVEs requiring local access to the device.

The IoT device categories had similar dominating vulnerability classes. Specifically, four of the top six primary classes (Memory Access, Tainted Input, Authentication, and Access Control) were common among all four IoT device categories. Risky Values was common for three categories, while Resource Management was among top six classes only for Other Traffic Devices, mainly due to vulnerabilities in the Qualcomm devices.

EV Chargers and Other Traffic Devices had the highest CVSS scores, much more critical and high severity vulnerabilities, and the highest percentage of Network related attack vectors among the four categories. Both categories had the median score of 7.8 and statistically significantly higher CVSS scores than EVs and Non-EVs. About 15% of CVEs in each category were of Critical severity. **Jason add here the percentages of high severity in each category.** Over 60% of CVEs in each category had Network related attack vectors. Additionally, they had the highest percentage of vulnerabilities that impacted Confidentiality, Integrity, and Availability at the same time - 58% and 62% for EV Chargers and Other Traffic Devices respectively.

EVs and Non-EVs had significantly lower CVSS scores, much less critical and high severity vulnerabilities, and significantly more Local and Physical attack vectors than the EV Chargers and Other Traffic Devices categories. Both categories had only around one quarter of CVEs accessible through the Network, while over half of their CVEs had Local or Physical attack vectors. Furthermore, over 95% of CVEs in each category had Unchanged scope (i.e., confined impact) which limits how far the damage can spread. Furthermore, these two categories had less CVEs that impact all three of Confidentiality, Integrity, and Availability, at 48% and 42% for EVs and Non-EVs, respectively.

The most common vulnerabilities for the devices considered in this paper are among MITRE's top 25 most dangerous CWEs [61]. For example, the most common CWE for EV chargers was CWE-78 OS Command Injection, which is ranked 9th on the top 25 dangerous CWEs list. Another common CWE-79 Cross-site Scripting is ranked 1st among top 25. The Memory Access vulnerabilities related to EVs and Non-EVs are also among the top 25, i.e., CWE-787 Out-of-bounds Write is 5th, CWE-120 Classic Buffer Overflow is 11th, CWE-122 Heap-based Buffer Overflow is 16th. For Other Traffic Devices, most of the common individual CWEs were among the top 25 most dangerous CWEs, including CWE-787 Out-of-Bounds Write (5th), CWE-416 Use After Free (7th), CWE-125 Out-of-Bounds Read (8th), and CWE-20 Improper Input Validation (18th). This high percentage of CWEs among top 25, especially for Other Traffic Devices, shows the importance of improving their security.

Many dominant vulnerability classes identified in this paper are among the OWASP Top 10 [62]. Thus, Access Control and Authentication, which were among the top six classes for all four categories, correspond to the Broken Access Control ranked 1st and Authentication Failures ranked 7th in the latest OWASP Top 10 list. Tainted Input is another common category which includes Injection vulnerabilities that are ranked 5th among the OWASP Top 10.

The findings of this study have the following actionable implications for developers, manufacturers, and researchers.

Focusing on the dominant CWE classes and individual prevalent CWEs is a cost-efficient way to improve the

security of transportation IoT devices. For example, security could be improved proactively by focusing on these vulnerabilities in the design phase and by composing a code review checklist that could be used during software development and verification to either avoid or detect and fix these vulnerabilities before they cause problems.

Specifically address persistent types of vulnerabilities such as out-of-bounds reads and writes, missing or broken authentication, command injections, and integer overflows that continue to prevail in spite the advances in cybersecurity. Factors that contribute to the persistence of dominant vulnerabilities include (i) use of languages like C and C++ that lack built-in memory safety mechanisms, (ii) absence of secure software development practices, (iii) use of third-party libraries, (iv) reuse of legacy systems, and (v) resource and cost constraints. Effectively addressing these persistent vulnerabilities would require both technical and organizational remediation strategies.

EV chargers development and deployment must prioritize cybersecurity because they impose significant risk not only to themselves but also to the vehicles and the power grid. EV charger vendors recommend to the owners to keep the software updated and not to connect the chargers to the public Internet [10] because about 65% of CVEs were exploitable through the network. Furthermore, close to 15% of CVEs (the most of all four categories) had a Changed scope, i.e., they could impact other components, managed by different security authorities.

Infotainment vulnerabilities, which are often shared between EVs and Non-EVs, need to be addressed to prevent lateral movement to the other parts of the vehicle or driver's smartphone. To mitigate such attacks, manufacturers should set up firewalls for the in-vehicle infotainment systems and apply the principle of least privilege to apps running on these systems [31].

Securing the Other Traffic Devices must be prioritized because close to 80% of their vulnerabilities had critical or high severity and they made up the majority of vulnerabilities in this study. Since 58% of these vulnerabilities were Memory Access related, the developers should focus on addressing them specifically, for example by transitioning to memory-safe languages and using secure coding practices.

Many dominant vulnerabilities in transportation IoT devices identified empirically in this study are among MITRE's top 25 and OWASP's top 10 vulnerabilities which demonstrates the high risk and further reinforces the importance of proactively addressing the security of IoT devices.

Our main findings about vulnerabilities reported for transportation IoT devices are as follows.

The considered transportation IoT devices had vulnerabilities reported in 16 out of the 23 primary classes. Out of these, the top 6 classes accounted for

72% of all vulnerabilities. The 6 most common primary classes for all of the IoT device categories together were Authentication, Channel, Information Leak, Memory Access, Other, and Tainted Input.

In each IoT device category, the 6 most common primary classes accounted for 74% to 89% of all reported vulnerabilities. For EV chargers, EVs, Non-EVs, and Other Traffic Devices, the top 6 classes contained 89%, 74%, 83%, and 88% of the vulnerabilities, respectively. This finding is consistent with the results presented in [4], which reported that security vulnerabilities in mission critical software were unevenly distributed, with the top 5 primary classes contributing from around 80% to 90% of vulnerabilities in each of the three datasets.

The most prominent vulnerability classes for EV Chargers were Authentication (30%), Information Leak (17%), and Tainted Input (19%). These indicate that EV chargers have problems with insecure passwords, insufficient authentication, encryption, data exposure or corruption, as well as possible injection attacks on their backend. Since EV chargers are typically accessible on the Internet [60] and have remote interfaces that support communication with the power grid, servers, and smartphones [22], the network attack vector is very prominent as indicated by our empirical results. Thus, most CWEs related to EV chargers were related to the front-end web interface (29.6%), the back-end web server (44.4%), and the communication protocol (11.1%).

The most common vulnerabilities for EVs were Memory Access (21%), Other (18%), and Tainted Input (11%). Half of the Memory Access vulnerabilities were CWE-787 Out-of-Bounds Write, showing that these types of vulnerabilities are still quite common. All 7 CWEs in the Other class were reported for BMW EVs and were attributed to CWE-693 Protection Mechanism Failure, which indicates a lack or incorrect use of protection mechanisms against attacks. Half of the Tainted Input CWEs were identified as CWE-20 Improper Input Validation. Note that EVs generally depend on software to function properly due to their Electronic Control Units (ECU), which manage engine safety, provide infotainment services [63], and regulate power supply, among other tasks. EVs are also often interconnected with ECUs of other vehicles and require Internet connections to keep the software updated and identify potential issues [64]. All 3 vulnerabilities that affected ECUs (i.e., CWE-77 Command Injection, CWE-20 Improper Input Validation, and CWE-74 Injection) belong to the Tainted Input class. In EVs, the majority of vulnerabilities were associated with the infotainment systems (47.3%), remote keyless entry (RKE) systems (13.1%), telematics control units (TCU) system (13.1%), and mobile apps (5.3%).

The most common vulnerabilities for Non-EVs were Channel (29%), Authentication (13%), and Tainted Input (13%). Six of the 7 Channel vulnerabilities were due to the RKE systems that allowed for replay attacks to unlock the vehicle by using the same signal every time. Two of the 3 Authentication CWEs were CWE-287 Improper Authentication indicating that the user's identity was not proven sufficiently before giving access. All 3 Tainted Input vulnerabilities were CWE-134 Use of Externally-Controlled Format String and were due to mishandling of format-string specifiers in device names for the vehicles' Bluetooth stacks. Interestingly, Non-EVs had the same vulnerable systems as EVs. Thus, the vulnerabilities were mostly associated with the infotainment system (20.8%), RKE (25%), mobile apps (29.2%) and TCU (12.5%). Although many Non-EVs are connected to the Internet, they seem to be less exposed to network attacks than EVs.

The most common vulnerabilities for Other Traffic Devices were Memory Access (33%), Access Control (18%), and Authentication (15%). Out of 11 Memory Access vulnerabilities, four were CWE-787 Out-of-bounds Write and one was CWE-125 Out-of-bounds Read, while others were related to buffer overflows (i.e., CWE-119 Improper Restriction of Operations within the Bounds of a Memory Buffer, CWE-120 Classic Buffer Overflow, and CWE-121 Stack-based Buffer Overflow). Of the 6 Access Control vulnerabilities, two were CWE-732 Incorrect Permission Assignment for Critical Resource and two were CWE-284 Improper Access Control. The Authentication vulnerabilities were all different and included CWE-307 Improper Restriction of Excessive Authentication Attempts, CWE-306 Missing Authentication for a Critical Function, and CWE-287 Improper Authentication, showing that weak or lack of authentication is a major problem. The vulnerable components included: dash cameras (45.4%), microcontrollers (42.4%), Econolite traffic control software (9.1%), and SWARCO traffic controller (3%). Most of the vulnerabilities in this category had network attack vectors because these devices are often accessed through the Internet or cellular networks. For example, many dash cameras have cellular connectivity for remote access to the footage.

There were similarities but also differences among the top six dominant vulnerability classes for different IoT devices categories. Other was the only vulnerability class that was among the top six classes for all four IoT device categories. Authentication, Channel, and Tainted Input were among the top six vulnerability classes for three IoT devices categories. Access Control, Cryptography, Information Leak, Memory Access, and Predictability were among top six vulnerability classes for two IoT devices categories, while Privilege was among the top six vulnerability classes only for one IoT devices category.

The most common vulnerabilities for transportation IoT devices identified in this paper are among MITRE's top 25 most dangerous CWEs [61]. For example, for EV chargers, we identified 4 instances of CWE-79 Cross-Site Scripting, 3 instances of CWE-352 Cross-Site Request Forgery, 4 instances of CWE-287 Improper Authentication, 4 instances of CWE-798 Use of Hard-coded credentials, and 3 instances of CWE-306 Missing Authentication for Critical Function, which are ranked 2nd, 9th, 13th, 18th, and 20th, respectively, on the top 25 most dangerous CWEs list. The dominant vulnerabilities for the other three categories of IoT devices were also among the top 25 most dangerous CWEs, but are not discussed here due to space limitations.

Many dominant vulnerability classes identified in this paper are also among the OWASP Top 10 Vulnerabilities [62]. For example, the Authentication class is similar to OWASP's Identification and Authentication Failures category, Access Control corresponds to OWASP's Broken Access control, and Tainted Input includes the OWASP's Injection category.

Our main findings related to CVSS scores and severity are as follows.

EV chargers category had the highest mean and median CVSS scores and the most critical severity among the four categories. For EV chargers, 94% of the vulnerabilities had a network attack vector, which means they can be exploited remotely, without physical access. The severity is likely high because when attacking an EV charging station with an Internet connection, attackers can gain unauthorized access beyond the charger, potentially allowing them to target critical components of the power grid or transportation network [65].

EVs and Other Traffic Devices had comparable mean and median CVSS scores. Note that Other Traffic Devices had a higher percentage of vulnerabilities with network attack vectors than EVs (i.e., 61% vs. 30%).

Non-EVs had the lowest mean and median CVSS scores, which were statistically significantly different from the CVSS scores of the other three categories. This may be due to the fact that Non-EVs had the lowest proportion of CVEs that were exploitable through the network (i.e., 21%), indicating that physical or adjacent attack vectors were more commonly used in the case of regular cars. However, note that there were fewer CVE reports for this category.

Our findings have the following actionable implications that could be useful for developers, manufacturers, and researchers.

Focusing on several dominant CWE classes is an efficient way to improve the security of transportation IoT devices. For example, this could be achieved by secure software development focused on avoiding these types of vulnerabilities and/or composing a code review checklist that

could be used in the software verification process.

Specifically address persistent types of vulnerabilities such as missing or improper authentication, improper input validation, command injection, information leak, and memory access including buffer overflow, which continue to prevail despite the advances in cybersecurity.

Development and deployment of EV chargers must account for cybersecurity because they pose a significant risk not only to themselves and EVs but also to the power grid. EV chargers had the highest number of reported CVEs and these CVEs had the highest mean and median CVSS scores.

Many transportation IoT devices (i.e., EV chargers, EVs and Other Traffic Devices) are typically accessible through the Internet and also have many vulnerabilities that can be exploited remotely, introducing broader attack vectors and high risk that, to be addressed, would require more rigorous design and implementation efforts.

Most vulnerabilities associated with transportation IoT devices empirically identified in this study are among MITRE's top 25 most dangerous CWEs and OWASP top 10 vulnerabilities which proves the existence of high risk and further reinforces the need for addressing the IoT devices security proactively.

IX. CONCLUSIONS

In this paper, we conducted an empirical study of security vulnerabilities in transportation IoT devices and vehicles. We focused on four different categories: EV Chargers, EVs, Non-EVs, and Other Traffic Devices. Our results showed that EV Chargers and Other Traffic Devices have statistically significantly higher severity levels than EVs and Non-EVs. In addition, the distribution of vulnerability classes is skewed, with the top six classes having between 65% and 86% of the total vulnerabilities in each category. EV Chargers had the highest proportion of CVEs that can be exploited from the network, as well as the highest percentage of CVEs that affect components outside of the scope of the original vulnerability. This extension of our previous paper compiled about 10 times as many vulnerabilities as before, along with compiled lessons learned and implications of our findings. These insights can be used by developers and researchers to effectively and efficiently improve the security of different types of transportation IoT devices.

This paper is focused on empirical analysis of security vulnerabilities. Specifically, we identified the dominant vulnerability classes in four IoT device categories: EV chargers, EVs, Non-EVs, and Other Traffic Devices. Our results showed that the distribution of the vulnerabilities is skewed, with the top six classes accounting for 74% to 89% of all vulnerabilities in each IoT device category. Furthermore, although the EV chargers had the highest CVSS scores, they were not statistically significantly different than the CVSS scores of EVs and Other Traffic Devices. The Non-EVs had the lowest CVSS

scores, which were statistically significantly different than the other categories of transportation IoT devices. In addition to compiling the lessons learned, we identified the implications of our findings and provided insights that can be used by researchers, developers, and manufacturers to cost-efficiently improve the security of transportation IoT devices.

Our future research includes (i) data triangulation (i.e., utilizing industry-specific databases as additional sources of information), and (ii) exploring attackers' behaviors that can lead to exploitation of identified vulnerabilities.

DATA AVAILABILITY

The dataset "Transportation-IoT-Vulnerabilities-DSN2025" used in this paper is licensed under CC BY-SA 4.0. The dataset's DOI is 10.5281/zenodo.15115541 and it is available at <https://zenodo.org/records/15115541>. Anyone using this dataset must include the attribution to this paper.

REFERENCES

- [1] J. Yih, K. Goseva-Popstojanova, and M. Cukier, "On security vulnerabilities in transportation iot devices," in *2025 55th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, 2025, pp. 589–598.
- [2] IBM, "X-Force Threat Intelligence Index 2025," 2025, accessed: 2025-11-04. [Online]. Available: <https://www.ibm.com/thought-leadership/institute-business-value/report/2025-threat-intelligence-index>
- [3] NIST, "National Vulnerability Database (NVD)," <https://nvd.nist.gov/>, 2025, accessed: 2025-02-24.
- [4] K. Goseva-Popstojanova and J. Tyo, "Experience report: Security vulnerability profiles of mission critical software: Empirical analysis of security related bug reports," in *IEEE 28th International Symposium on Software Reliability Engineering (ISSRE)*, 2017, pp. 152–163.
- [5] Common Weakness Enumeration, "CWE-888: Software Fault Pattern (SFP) Clusters," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/888.html>
- [6] W. Xiong, M. Gülsever, K. M. Kaya, and R. Lagerström, "A study of security vulnerabilities and software weaknesses in vehicles," in *Secure IT Systems: 24th Nordic Conference, NordSec 2019*. Springer, 2019, pp. 204–218.
- [7] K. M. Kaya, "A study of vulnerabilities and weaknesses in connected cars," KTH Royal Institute of Technology, Tech. Rep., June 30 2019. [Online]. Available: <https://www.diva-portal.org/smash/get/diva2:1356203/FULLTEXT01.pdf>
- [8] M. Gulsever, "A study on vulnerabilities in connected cars," KTH Royal Institute of Technology, Tech. Rep., June 7 2019. [Online]. Available: <https://www.diva-portal.org/smash/get/diva2:1351157/FULLTEXT01.pdf>
- [9] S. Basu and M. Staron, "Understanding the changing landscape of automotive software vulnerabilities: Insights from a seven-year analysis," in *2025 IEEE/ACM 3rd International Workshop on Software Vulnerability Management (SVM)*. IEEE, May 2025, p. 9–16. [Online]. Available: <http://dx.doi.org/10.1109/SVM66695.2025.00006>
- [10] R. Plaka, M. Asplund, and S. Nadjm-Tehrani, "Vulnerability analysis of an electric vehicle charging ecosystem," in *International Conference on Critical Information Infrastructures Security*. Springer, 2023, pp. 155–173.
- [11] IBM, "X-Force Threat Intelligence Index 2024," 2024, accessed: 2025-02-24. [Online]. Available: <https://www.ibm.com/downloads/cas/JZ7GZ6XR>
- [12] P. Bhattacharya, L. Ulanova, I. Neamtiu, and S. C. Koduru, "An empirical analysis of bug reports and bug fixing in open source Android apps," in *2013 17th European Conference on Software Maintenance and Reengineering*. IEEE, 2013, pp. 133–143.
- [13] M. Jimenez, M. Papadakis, T. F. Bissyande, and J. Klein, "Profiling Android vulnerabilities," in *IEEE International Conference on Software Quality, Reliability and Security (QRS)*, 2016, pp. 222–229.

- [14] A. Gorbenko, A. Romanovsky, O. Tarasyuk, and O. Biloborodov, "Experience report: Study of vulnerabilities of enterprise operating systems," in *28th IEEE International Symposium on Software Reliability Engineering (ISSRE)*, 2017, pp. 205–215.
- [15] —, "From analyzing operating system vulnerabilities to designing multiversion intrusion-tolerant architectures," *IEEE Transactions on Reliability*, vol. 69, no. 1, pp. 22–39, 2020.
- [16] M. J. Ahmad and K. Goseva-Popstojanova, "Exploring the generalizability of software vulnerability classes via replication and synthesis," in *2025 IEEE 36th International Symposium on Software Reliability Engineering (ISSRE)*. IEEE, 2025, pp. 478–489.
- [17] M. Vålja, M. Korman, and R. Lagerström, "A study on software vulnerabilities and weaknesses of embedded systems in power networks," in *2nd Workshop on Cyber-Physical Security and Resilience in Smart Grids*, 2017, p. 47–52.
- [18] N. S. Harzevili, J. Shin, J. Wang, S. Wang, and N. Nagappan, "Characterizing and understanding software security vulnerabilities in machine learning libraries," in *2023 IEEE/ACM 20th International Conference on Mining Software Repositories (MSR)*. IEEE, 2023, pp. 27–38.
- [19] M. Alfadel, D. E. Costa, and E. Shihab, "Empirical analysis of security vulnerabilities in Python packages," *Empirical Software Engineering*, vol. 28, no. 3, p. 59, 2023.
- [20] W. Jiang, D. Pressato, H. Darji, and T. Lutellier, "Exploring the jupyter ecosystem: An empirical study of bugs and vulnerabilities," *arXiv preprint arXiv:2507.18833*, 2025.
- [21] B. Saleem and Z. Muhammad, "A survey of critical cybersecurity risks in electric vehicle mobile applications: Vulnerabilities, permissions, and mitigation strategies," 2025.
- [22] S. Acharya, Y. Dvorkin, H. Pandžić, and R. Karri, "Cybersecurity of smart electric vehicle charging: A power grid perspective," *IEEE Access*, vol. 8, pp. 214 434–214 453, 2020.
- [23] D. Ronanki and H. Karneddi, "Electric vehicle charging infrastructure: Review, cyber security considerations, potential impacts, countermeasures, and future trends," *IEEE Journal of Emerging and Selected Topics in Power Electronics*, vol. 12, no. 1, pp. 242–256, 2024.
- [24] R. Anjana and V. Kumar, "Comprehensive review of electric vehicle charging infrastructure vulnerabilities and defense against malicious attacks," in *2024 International Conference on IoT, Communication and Automation Technology (ICICAT)*, 2024, pp. 1631–1638.
- [25] A. Stichow and P. Rempel, "Securing electric vehicle charging stations: A critical analysis of authentication vulnerabilities," in *2024 IEEE 32nd International Requirements Engineering Conference Workshops (REW)*, 2024, pp. 231–240.
- [26] T. Nasr, S. Torabi, E. Bou-Harb, C. Fachkha, and C. Assi, "Power jacking your station: In-depth security analysis of electric vehicle charging station management systems," *Computers Security*, vol. 112, p. 102511, 2022.
- [27] S. Shirvani, Y. Baseri, and A. Ghorbani, "Evaluation framework for electric vehicle security risk assessment," *IEEE Transactions on Intelligent Transportation Systems*, vol. 25, no. 1, pp. 33–56, 2024.
- [28] J. Johnson, B. Anderson, B. Wright, J. Quiroz, T. Berg, R. Graves, J. Daley, K. Phan, M. Kunz, R. Pratt, T. Carroll, L. R. O'Neil, B. Dindlebeck, P. Maloney, J. O'Brien, D. Gotthold, R. Varriale, T. Bohn, and K. Hardy, "Cybersecurity for electric vehicle charging infrastructure," 2022, accessed: 2025-02-24. [Online]. Available: <https://www.osti.gov/biblio/1877784>
- [29] Y. Feng, S. E. Huang, W. Wong, Q. A. Chen, Z. M. Mao, and H. X. Liu, "On the cybersecurity of traffic signal control system with connected vehicles," *IEEE Transactions on Intelligent Transportation Systems*, vol. 23, no. 9, pp. 16 267–16 279, 2022.
- [30] I. Durlík, T. Miller, E. Kostecka, Z. Zwierzewicz, and A. Łobodzińska, "Cybersecurity in autonomous vehicles—are we ready for the challenge?" *Electronics*, vol. 13, no. 13, p. 2654, 2024.
- [31] S. Jeong, M. Ryu, H. Kang, and H. K. Kim, "Infotainment system matters: Understanding the impact and implications of in-vehicle infotainment system hacking with automotive grade linux," in *Proceedings of the Thirteenth ACM Conference on Data and Application Security and Privacy*, ser. CODASPY '23. New York, NY, USA: Association for Computing Machinery, 2023, p. 201–212. [Online]. Available: <https://doi.org/10.1145/3577923.3583650>
- [32] N. Bhusal, M. Gautam, and M. Benidris, "Cybersecurity of electric vehicle smart charging management systems," in *2020 52nd North American Power Symposium (NAPS)*, 2021, pp. 1–6.
- [33] Z. Pourmirza and S. Walker, "Electric vehicle charging station: Cyber security challenges and perspective," in *2021 IEEE 9th International Conference on Smart Energy Grid Engineering (SEGE)*, 2021, pp. 111–116.
- [34] Z. Muhammad, Z. Anwar, and B. Saleem, "A cybersecurity risk assessment of electric vehicle mobile applications: Findings and recommendations," in *2023 3rd International Conference on Artificial Intelligence (ICAI)*, 2023, pp. 45–51.
- [35] P. Sharma and J. Gillanders, "Cybersecurity and forensics in connected autonomous vehicles: A review of the state-of-the-art," *IEEE Access*, vol. 10, pp. 108 979–108 996, 2022.
- [36] Saascharge, "CHARGING STATION OEM LIST," 2025. [Online]. Available: <https://saascharge.com/charging-station-oem-list/>
- [37] Internal Revenue Service, "Manufacturers and models for new qualified clean vehicles purchased in 2022 and before," 2023, accessed: 2025-02-24. [Online]. Available: <https://www.irs.gov/credits-deductions/manufacturers-and-models-for-new-qualified-clean-vehicles-purchased-in-2022-and-before>
- [38] U.S. News and World Report, "All the Car Brands Available in America," 2023, accessed: 2025-02-24. [Online]. Available: <https://cars.usnews.com/cars-trucks/advice/car-brands-available-in-america>
- [39] Qualcomm, "Products," 2025. [Online]. Available: <https://www.qualcomm.com/products>
- [40] VulDB, "Vulnerability Database and Vulnerability Intelligence," <https://vuldb.com/>, 2024, accessed: 2025-02-24.
- [41] VicOne, "Automotive Zero-Day Vulnerabilities," <https://vicone.com/automotive-zero-day-vulnerabilities>, 2024, accessed: 2025-02-24.
- [42] Electric Drive Transportation Association, "Charging Equipment Showroom," 2023, accessed: 2025-02-24. [Online]. Available: <https://www.golectricdrive.org/charging-ev/charging-equipment-showroom>
- [43] H. Wen, Q. A. Chen, and Z. Lin, "Plug-N-Pwned: Comprehensive vulnerability analysis of OBD-II dongles as a new Over-the-Air attack surface in automotive IoT," in *29th USENIX Security Symposium*, 2020, pp. 949–965.
- [44] National Vulnerability Database (NVD), "NVD CWE Slice," <https://nvd.nist.gov/vuln/categories>, 2023, accessed: 2025-02-24.
- [45] Common Vulnerability Scoring System (CVSS), "Specification Document," Online: <https://www.first.org/cvss/v4.0/specification-document>, 2023, accessed: 2025-02-24.
- [46] Common Weakness Enumeration, "CWE," 2024, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/index.html>
- [47] —, "CWE-699: Software Development," Online: <https://cwe.mitre.org/data/definitions/699.html>, 2023, accessed: 2025-02-24.
- [48] —, "CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') ," 2023. [Online]. Available: <https://cwe.mitre.org/data/definitions/78.html>
- [49] M. A. Sayed, R. Atallah, C. Assi, and M. Debbabi, "Electric vehicle attack impact on power grid operation," *International Journal of Electrical Power and Energy Systems*, vol. 137, p. 107784, May 2022. [Online]. Available: <http://dx.doi.org/10.1016/j.ijepes.2021.107784>
- [50] Common Weakness Enumeration, "CWE-693: Protection Mechanism Failure," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/693.html>
- [51] S. Nie, L. Liu, and Y. Du, "Free-fall: Hacking tesla from wireless to can bus," *Briefing, Black Hat USA*, vol. 25, no. 1, p. 16, 2017.
- [52] J. Ungood-Thomas, "Gone in 20 seconds: how 'smart keys' have fuelled a new wave of car crime," *The Guardian*, February 24 2024, accessed: February 9, 2026. [Online]. Available: <https://www.theguardian.com/money/2024/feb/24/smart-keys-car-crime-thieves-hi-tech-arms-race>
- [53] National Vulnerability Database, "CVE-2018-9322 Detail," 2018, accessed: 2025-02-24. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2018-9322>
- [54] Common Weakness Enumeration, "CWE-294: Authentication Bypass by Capture-replay ," 2023, accessed: 2025-02-24. [Online]. Available: <https://cwe.mitre.org/data/definitions/294.html>

- [55] National Vulnerability Database, "CVE-2022-37305 Detail," 2022, accessed: 2025-02-24. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2022-37305>
- [56] P. Chua, G. Chen, A. Tan, C. P. Tan, R.-S. Tan, and B. Cao, "Drivethru hacking: Fast food, faster data breach."
- [57] E. Coppens, "Os command injection in cph2 charging station [2.0.0 (cve-2023-46359 and cve-2023-46360)," Offensivity Blog, Dec. 2023. [Online]. Available: <https://www.offensivity.com/en/blog/os-command-injection-in-cph2-charging-station-200-cve-2023-46359-and-cve-2023-46360/>
- [58] SadFud, "cir-pwn-life: Exploits for circontrol circularlife," GitHub repository, 2018, accessed: 2025-02-03. [Online]. Available: <https://github.com/SadFud/Exploits/tree/master/Real%20World/Suites/cir-pwn-life>
- [59] Upstream, "Upstream AutoThreat® Intelligence Cyber Incident Repository," <https://upstream.auto/research/automotive-cybersecurity/?id=null>, 2024, accessed: 2025-02-24.
- [60] J. Johnson, T. Berg, B. Anderson, and B. Wright, "Review of electric vehicle charger cybersecurity vulnerabilities, potential impacts, and defenses," *Energies*, vol. 15, no. 11, 2022. [Online]. Available: <https://www.mdpi.com/1996-1073/15/11/3931>
- [61] MITRE Top 25, "CWE Top 25 Most Dangerous Software Weaknesses," https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html, 2025, accessed: 2025-07-27.
- [62] OWASP Top 10, "OWASP Top 10 CWEs," 2025, accessed: 2026-07-27. [Online]. Available: <https://owasp.org/Top10/2025/>
- [63] C. Bernardini, M. R. Asghar, and B. Crispo, "Security and privacy in vehicular communications: Challenges and opportunities," *Vehicular Communications*, vol. 10, pp. 13–28, 2017. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2214209617300803>
- [64] S. Prasad, "Connected vehicle ecosystem – Why do electric vehicles need connectivity?" *EVreporter*, 2022. [Online]. Available: <https://evreporter.com/connected-vehicle-ecosystem-why-do-e-vehicles-need-connectivity/>
- [65] S. Hamdare, O. Kaiwartya, M. Aljaidi, M. Jugran, Y. Cao, S. Kumar, M. Mahmud, D. Brown, and J. Lloret, "Cybersecurity risk analysis of electric vehicles charging stations," *Sensors*, vol. 23, p. 6716, July 2023.